

Change Advisory Remediation Pack

CAB-friendly remediation document with implementation, rollback, and validation sections.

Report Type	Remediation
Tool Source	Tenable.sc
Reporting Date	July 2026
Document Type	Remediation Guide

Contents

1. Change Summary
2. Implementation Plan
3. Rollback Guidance
4. Validation Plan

1. Change Summary

Finding	Asset	CVE	Primary Action
Apache Tomcat AJP Request Injection and Potential RCE	10.20.1.234 / web-prod-01 / TCP 8009	CVE-2020-1938	Confirm whether the affected host is running a vulnerable Tomcat release and whether AJP is listening on TCP 8009.
SSL Certificate Cannot Be Trusted	10.20.1.235 / vpn-gw-02 / TCP 443	Not provided	Identify the service, hostname, port, certificate subject, issuer, expiry, and chain presented by the affected asset.
Microsoft SQL Server Unsupported Version Detection	10.20.2.118 / sql-prod-03 / TCP 1433	Not provided	Confirm the SQL Server version, edition, product level, and build number.

2. Implementation Plan

2.1 Apache Tomcat AJP Request Injection and Potential RCE

Affected Asset	10.20.1.234 / web-prod-01 / TCP 8009
CVE	CVE-2020-1938
Reference Links	https://tomcat.apache.org/security-9.html https://nvd.nist.gov/vuln/detail/CVE-2020-1938

Pre-Change Checks

- Confirm whether the affected host is running a vulnerable Tomcat release and whether AJP is listening on TCP 8009.
- Confirm maintenance window and business owner approval.
- Confirm backup, snapshot, or rollback evidence exists.

Implementation Steps

- If AJP is not required, disable the AJP connector in server.xml and restart Tomcat.
- If AJP is required, upgrade Tomcat to a fixed release and restrict AJP to a trusted interface or loopback address.
- Configure an AJP shared secret when AJP must remain enabled, and align the reverse proxy connector with the same secret.
- Confirm TCP 8009 is not reachable from untrusted networks after the change.

Rollback Guidance

If the change causes service impact, revert the configuration backup or restore the approved pre-change snapshot, restart the affected service, and validate service health before closing the change.

Command Examples

Identify Tomcat version and AJP listener
<pre># Run on the Tomcat host export CATALINA_BASE=\${CATALINA_BASE:-/opt/tomcat} export CATALINA_HOME=\${CATALINA_HOME:-/opt/tomcat} \$CATALINA_HOME/bin/version.sh sudo ss -lntp grep ':8009' true sudo grep -R "protocol=\\"AJP\\" \"\$CATALINA_BASE/conf\" \"\$CATALINA_HOME/conf\" 2>/dev/null</pre>

2.2 SSL Certificate Cannot Be Trusted

Affected Asset	10.20.1.235 / vpn-gw-02 / TCP 443
CVE	Not provided

Reference Links	https://www.tenable.com/plugins/nessus/51192 https://docs.tenable.com/whitepapers/useful-plugins/Content/UsefulPlugins/Resolving51192.htm https://docs.openssl.org/3.0/man1/openssl-s_client/ https://docs.openssl.org/3.0/man1/openssl-verify/
-----------------	--

Pre-Change Checks

- Identify the service, hostname, port, certificate subject, issuer, expiry, and chain presented by the affected asset.
- Confirm maintenance window and business owner approval.
- Confirm backup, snapshot, or rollback evidence exists.

Implementation Steps

- If the certificate is self-signed or issued by an internal CA, either replace it with an approved publicly trusted certificate or add the internal CA to the scanner trust configuration where appropriate.
- If the certificate chain is incomplete, install the required intermediate certificates on the service.
- If the certificate is expired or has the wrong subject/SAN, request and deploy a corrected certificate from the approved CA.
- Rerun the scan after the certificate chain validates cleanly.

Rollback Guidance

If the change causes service impact, revert the configuration backup or restore the approved pre-change snapshot, restart the affected service, and validate service health before closing the change.

Command Examples

Collect certificate and chain from the service	
<pre># Replace DNS and port with the affected service from the CSV openssl s_client -connect vpn-gw-02:443 -servername vpn-gw-02 -showcerts </dev/null > vpn-gw-02_chain.txt openssl x509 -in vpn-gw-02_chain.txt -noout -subject -issuer -dates -ext subjectAltName</pre>	

2.3 Microsoft SQL Server Unsupported Version Detection

Affected Asset	10.20.2.118 / sql-prod-03 / TCP 1433
CVE	Not provided
Reference Links	https://learn.microsoft.com/en-us/sql/sql-server/end-of-support/sql-server-end-of-support-overview https://learn.microsoft.com/en-us/troubleshoot/sql/releases/find-my-sql-version https://learn.microsoft.com/en-us/troubleshoot/sql/releases/download-and-install-latest-updates https://learn.microsoft.com/en-us/sql/database-engine/install-windows/upgrade-sql-server

Pre-Change Checks

- Confirm the SQL Server version, edition, product level, and build number.
- Confirm maintenance window and business owner approval.
- Confirm backup, snapshot, or rollback evidence exists.

Implementation Steps

- Compare the detected build with Microsoft lifecycle and latest-update guidance.
- Back up all affected databases and verify the backup before upgrade or migration.
- Choose the remediation path: in-place upgrade, side-by-side migration, Azure SQL migration, or Extended Security Updates when eligible.
- Patch to a supported SQL Server build and rerun validation queries after upgrade.

Rollback Guidance

If the change causes service impact, revert the configuration backup or restore the approved pre-change snapshot, restart the affected service, and validate service health before closing the change.

Command Examples

Identify SQL Server version and edition

```
-- Run in SSMS or sqlcmd against the affected instance
SELECT @@VERSION;
SELECT
    SERVERPROPERTY('ProductVersion') AS ProductVersion,
    SERVERPROPERTY('ProductLevel') AS ProductLevel,
    SERVERPROPERTY('Edition') AS Edition;
```